A–Z WALKTHROUGH · CAPSTONE 2

PhishAwareness — every screen, end to end

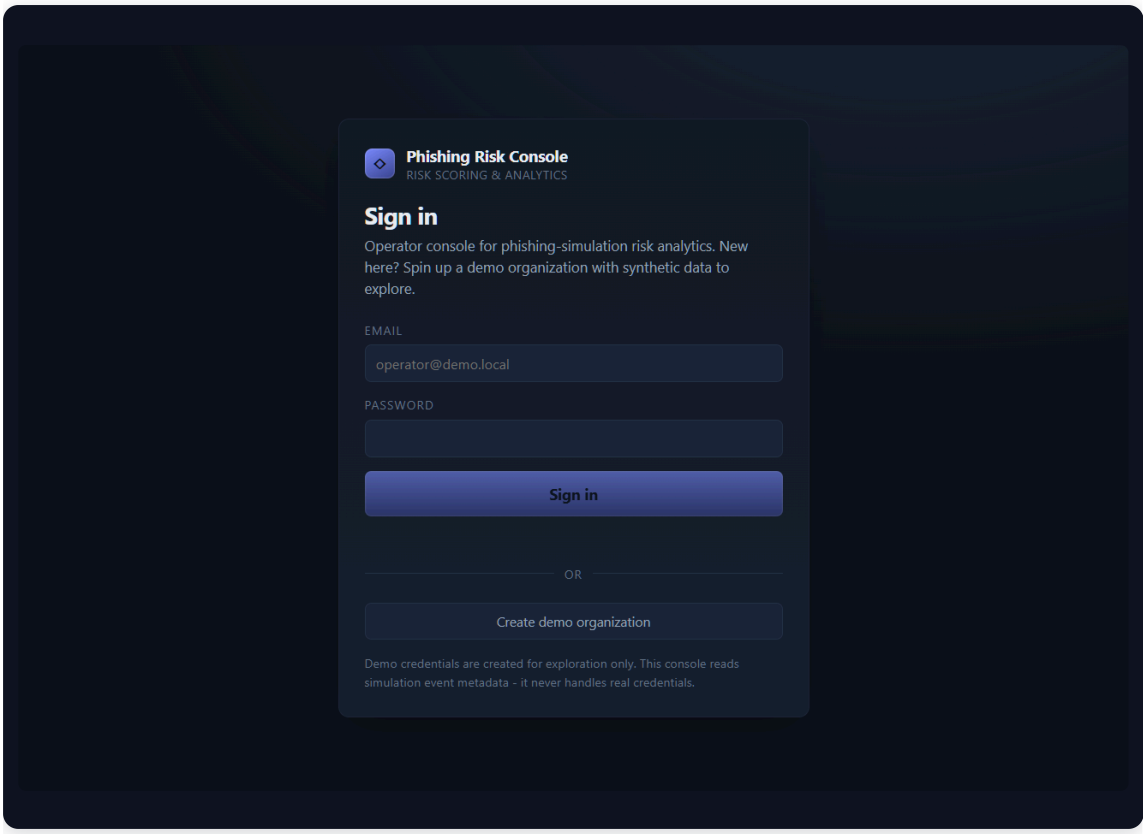
Generated from the live application · annotated screenshots, in order of use

This is the fastest way to see how the console actually works: every screen below is a real screenshot of the running application, working through the whole loop — sign in, read the dashboards, drill into a person, manage the programme, and wire up the two integrations added in the latest security pass (per-tenant GoPhish TLS verification, and the portal's least-privilege service token).

- Measurement layer — FastAPI backend, React console (this walkthrough)
- GoPhish — the separate, authorised delivery tool (not shown here; see *GoPhish_Runbook.md*)
- Awareness & Remediation Portal — the companion training service (see *PORTAL_GUIDE.md*)

STEP A

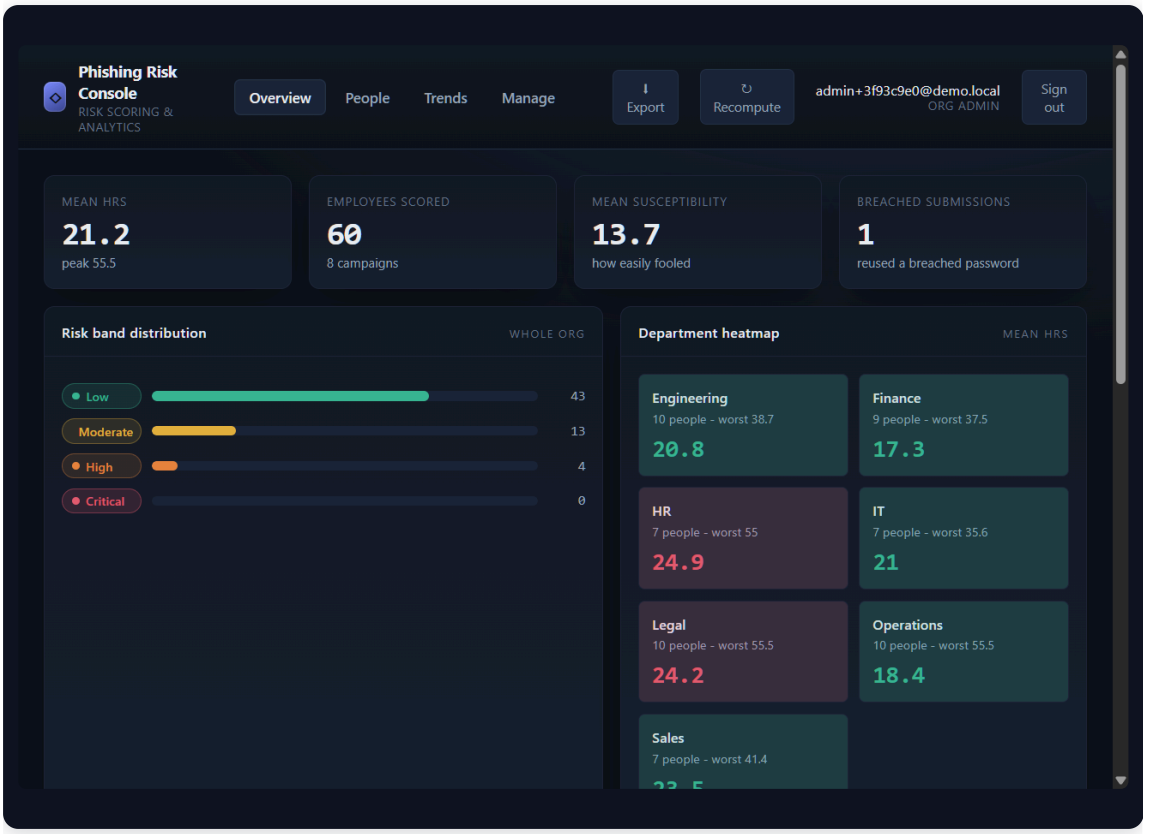
Sign in, or spin up a demo organisation



The console never handles a real credential of its own beyond the operator's login. New to the platform? **Create demo organization** seeds sixty synthetic employees and eight campaigns, computes scores, and hands back one demo login per role (org admin, operator, department viewer) so you can explore immediately — no external data or GoPhish instance required.

STEP B

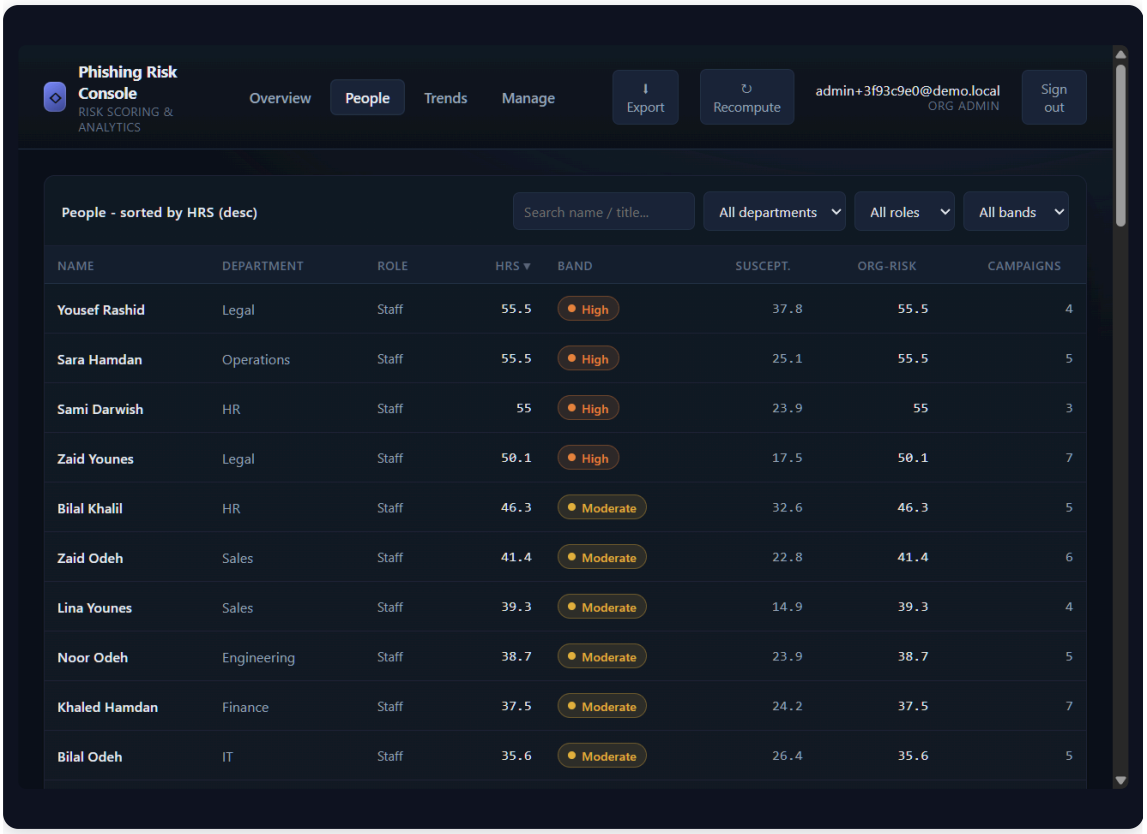
Overview — the landing dashboard



Four headline KPIs (mean HRS, employees scored, mean susceptibility, breached submissions), the risk-band distribution across the whole org, a per-department heatmap, and the organisation's HRS trend below the fold. **Recompute** re-scores from the latest events; **Export** downloads the current scores as CSV.

STEP C

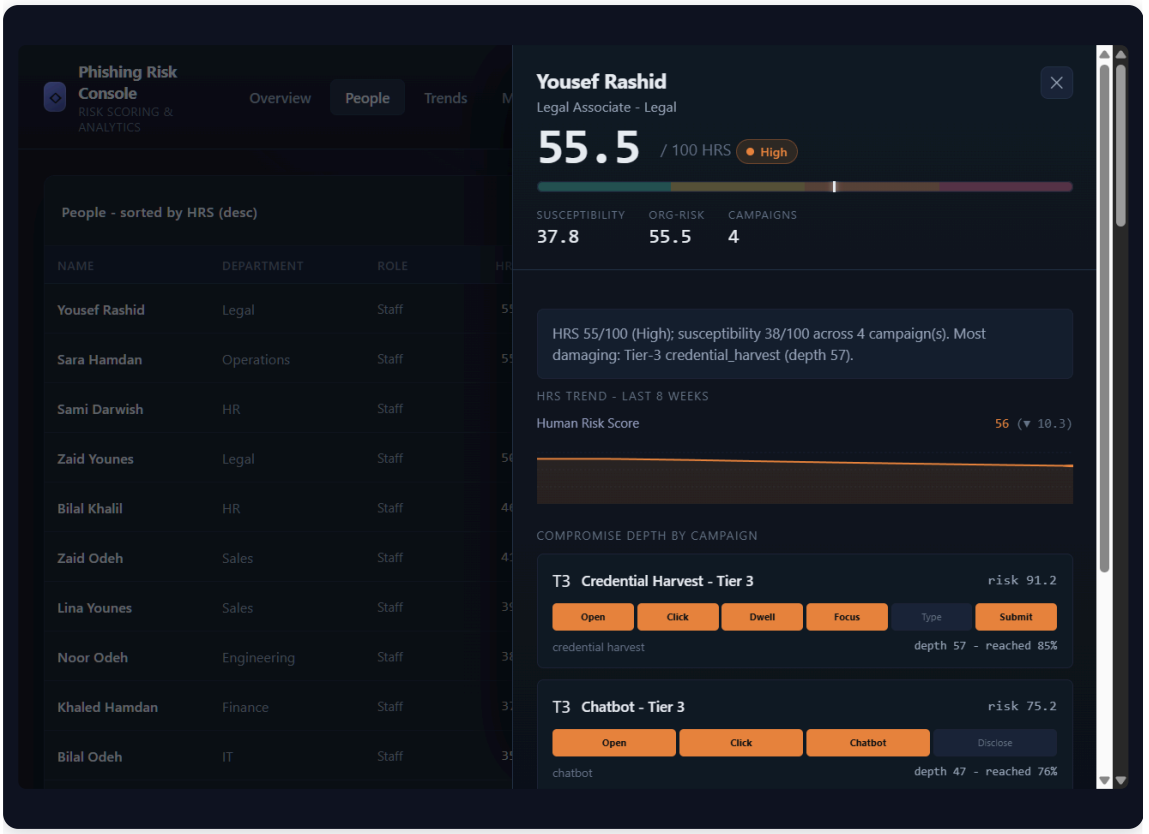
People — everyone, ranked



Every employee ranked by Human Risk Score, filterable by department, role, and band, searchable by name or title. Org-risk is HRS × role sensitivity, shown as a separate column so a senior title never inflates the individual score itself. Click any row to drill in.

STEP D

The drill-down — the evidence behind the number



The signature compromise-depth ladder for every campaign this person was targeted in — exactly which stages they reached (opened → clicked → dwelled → focused a field … submitted, or the chatbot/download equivalents) — plus an HRS trend sparkline and a one-line plain-English explanation of what drove the score.

STEP E

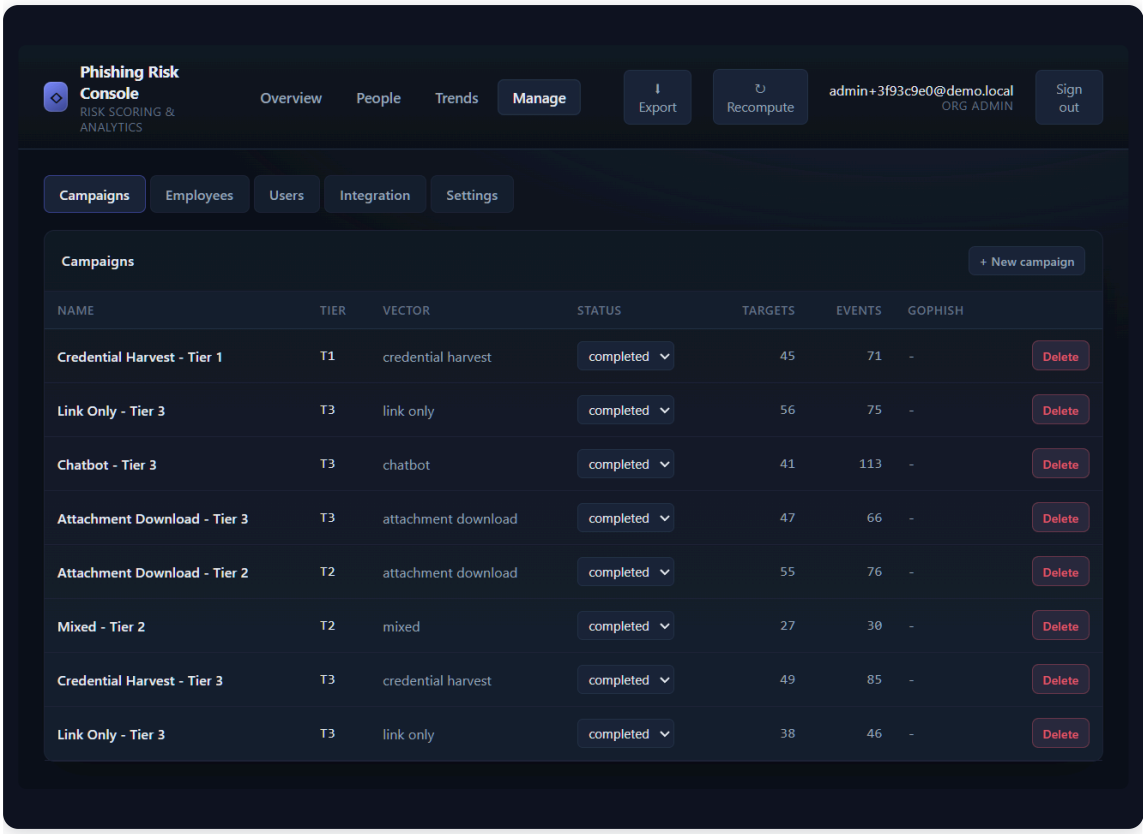
Trends — is the organisation improving?



Organisation mean HRS over an 8/12/26-week window, with a High/Critical head-count overlay. The 90-day decay half-life means old failures fade in weight, so a programme that is genuinely improving trends visibly downward rather than staying flat.

STEP F

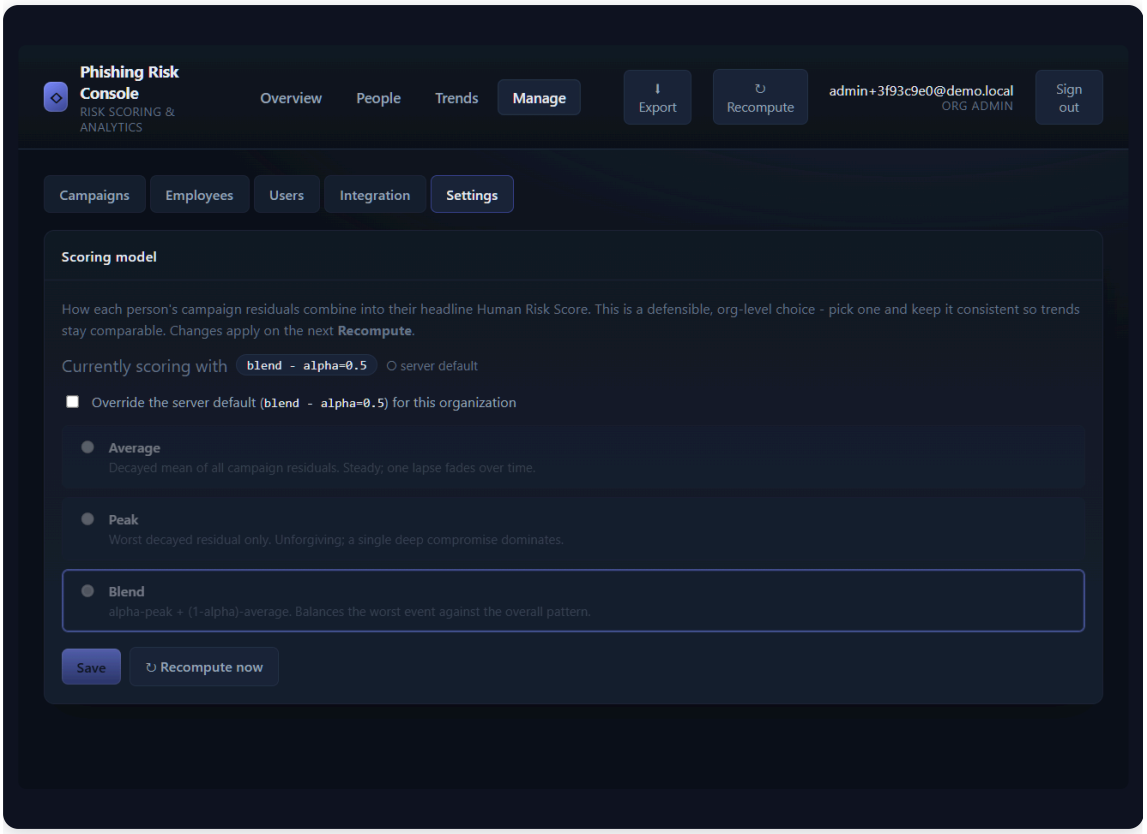
Manage → Campaigns



Create and edit campaigns: set the difficulty tier (1–3) and attack vector, and link each to its GoPhish campaign id via `external_ref` so inbound webhook/beacon events map to the right campaign automatically. With GoPhish sync on, this linking happens on its own.

STEP G

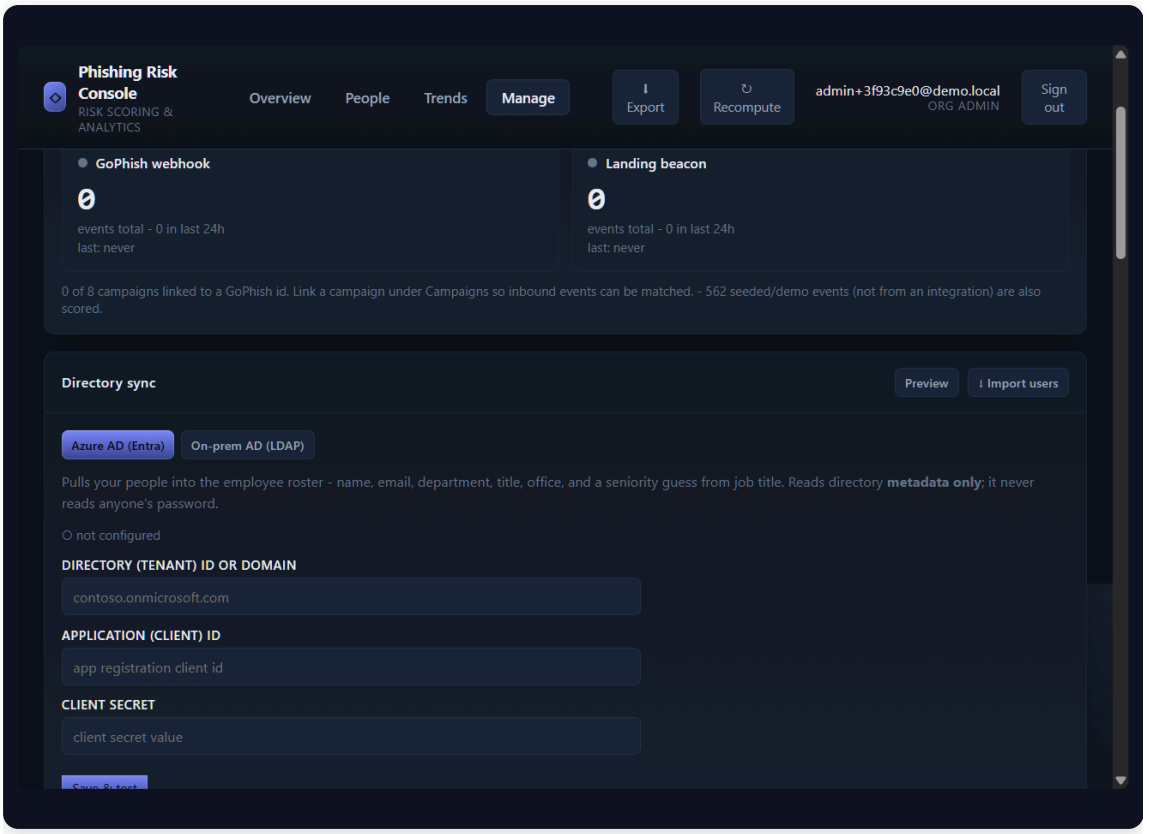
Manage → Settings



Change the scoring aggregation model — average, peak, or blend, with a tunable blend-α — live from the UI, then recompute. Backed by a per-tenant setting, so the model can be tuned and defended without a redeploy.

STEP H

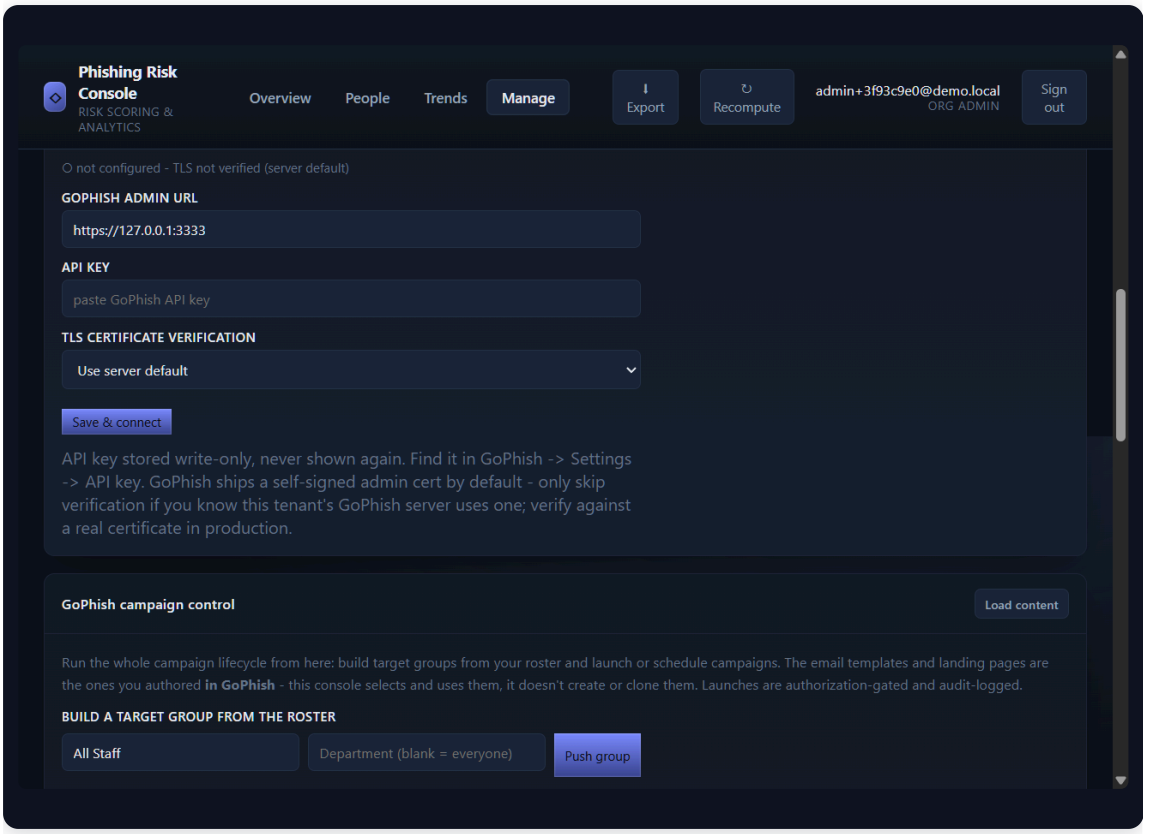
Manage → Integration — live connection health



Live proof the pipeline is receiving data: inbound event metadata counted by source (GoPhish webhook and landing beacon), with totals, last-24h counts, and last-seen timestamps. Directory sync (Entra ID shown; on-prem LDAP is a second tab) lets an admin wire up the roster source, test the connection, preview the mapping, and import.

STEP I · NEW IN THIS HARDENING PASS

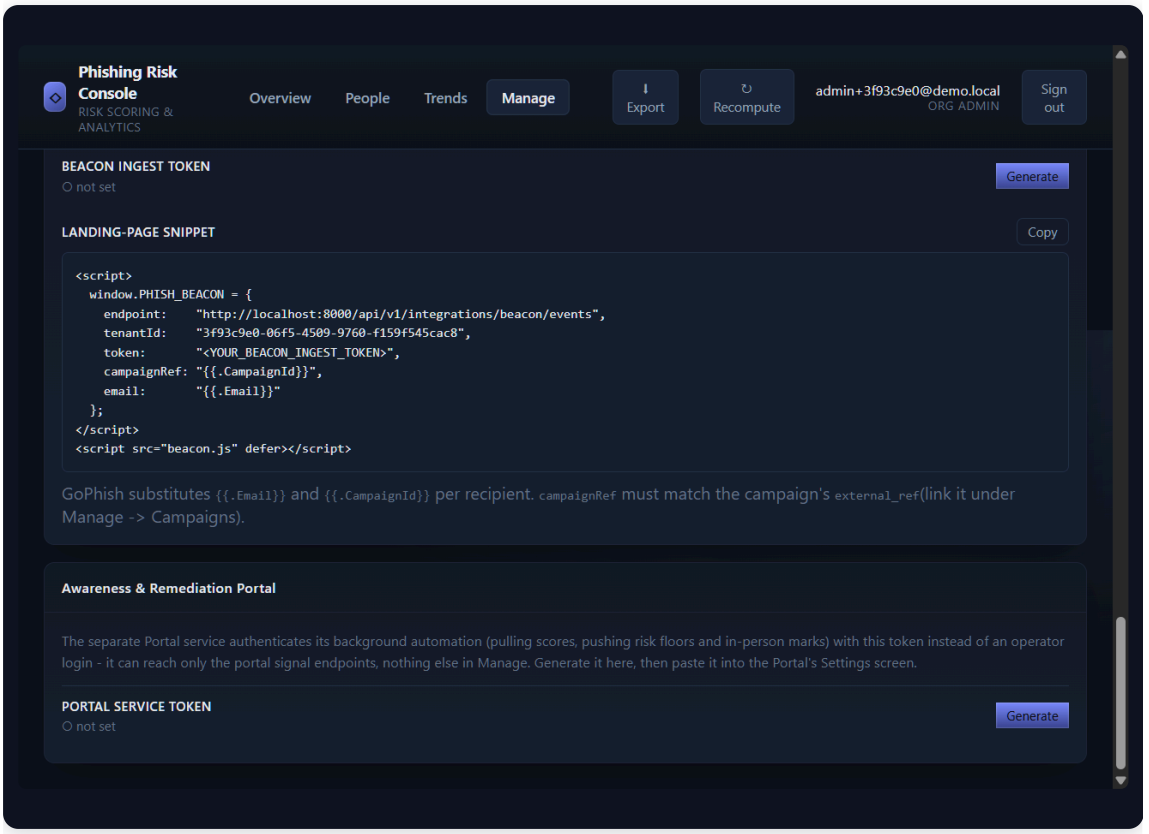
Manage → Integration — GoPhish sync, with per-tenant TLS



Set the GoPhish admin URL and API key (stored write-only, encrypted at rest). The **TLS certificate verification** selector is new: each tenant can verify, skip, or inherit the server default independently — so one tenant's self-signed GoPhish certificate can no longer force every other tenant on the same deployment to also disable verification.

STEP J · NEW IN THIS HARDENING PASS

Manage → Integration — the portal service token



The Awareness & Remediation Portal's background automation used to authenticate with a stored operator email and password. It now authenticates with this dedicated, rotatable token instead — generated here, encrypted at rest, and scoped to exactly the five portal-signal endpoints. A leaked token can no longer reach campaign launch, the roster, or user management.